

Dlaczego warto wdrożyć MFA w firmie?



O MNIE



W życiu zawodowym
konsultant, Microsoft
Certified Trainer,
administrator, programista,
freelancer, czasami magik.



Visual C#, SQL Server,
SharePoint, Azure



Prywatne życie w liczbach:
1 mąż, 1 córka, 1 kot i 2 psy.
Moje hobby to kryminały,
praca w ogrodzie i pasieka.



info@zalnet.pl



[facebook.com
/zalnet.beata.zalewa](https://facebook.com/zalnet.beata.zalewa)



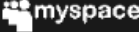
www.zalnet.pl

Agenda

- Eliminacja haseł oraz klucze sprzętowe i aplikacje mobilne
- Koncepcja Zero Trust
- Multi-Factor Authentication
- Praca zdalna a bezpieczeństwo
- Obniżenie kosztów zarządzaniu dostępem



Wycieki danych

Largest breaches		Recently added breaches	
	772,904,991 Collection #1 accounts		349,627 Brand New Tube accounts
	763,117,241 Verifications.io accounts		10,001,355 Stripchat accounts
	711,477,622 Onliner Spambot accounts		7,455,386 START accounts
	622,161,052 Data Enrichment Exposure From PDL Customer accounts		2,107,000 Banorte accounts
	593,427,119 Exploit.In accounts		1,021,790 SitePoint accounts
	509,458,528 Facebook accounts		23,817 Shitexpress accounts
	457,962,538 Anti Public Combo List accounts		6,682,453 Twitter accounts
	393,430,309 River City Media Spam List accounts		22,229,637 QuestionPro accounts
	359,420,698 MySpace accounts		985,586 Tuned Global accounts
	268,765,495 Wattpad accounts		437,928 Mecho Download accounts

Co możemy zrobić?

- Zazwyczaj nie możesz powstrzymać wycieku danych, ale możesz stworzyć swoje hasło mniej przydatne dla hakerów
- Jak? Jeśli to możliwe, użyj bardziej złożonego hasła
- MFA w dzisiejszych czasach wydaje się być koniecznością
- Nawet jeśli ktoś uzyska dostęp do Twojego hasła, możesz być chroniony

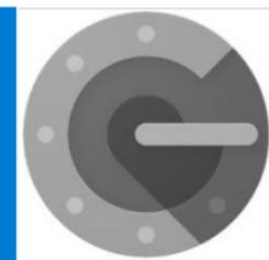
Co to jest MFA?

- MFA oznacza uwierzytelnianie wieloskładnikowe (Multi-Factor Authentication)
- To dodatkowa warstwa zabezpieczeń chroniąca konta przed złośliwymi atakami.
- Zapewnienie dodatkowego czynnika logowania w celu zweryfikowania tożsamości



Co to jest MFA?

- Przeszło dwa lata temu Gartner przewidywał, że do 2022 r. 60 % korporacji i globalnie działających przedsiębiorstw oraz 90 % średnich przedsiębiorstw wdroży metody bezhasłowe w ponad 50 % zastosowań, co miało być ogromnym wzrostem w porównaniu z 5 proc. w 2018 r.
- Obecnie, w dużych organizacjach całkowite odejście od haseł jest mało prawdopodobne.
- Klucze sprzętowe i aplikacje mobilne mogą być wykorzystywane jako drugi składnik uwierzytelniający.



Dlaczego MFA?

- Pieniądze są często wydawane na wdrażanie praktyk, które nie chronią przed wyrafinowanymi zagrożeniami i nadal wspierają tylko bezpieczeństwo haseł
- Według danych w ponad 80% wycieków związanych z włamaniami wykorzystano skradzione i/lub słabe hasła
- Informacja jest największym atutem firmy
- Zabezpieczenia i ochrona naszych kont
- Zatrzymuje rozprzestrzenianie się złośliwych/spamowych wiadomości e-mail wewnątrz i zewnątrz

Dlaczego MFA?

- Skomplikowane hasła są trudne do zapamiętania. Użytkownicy zapisują je i łączą popularne słowa z łatwymi do odnalezienia informacjami.
- Użytkownicy po prostu próbują wykonać swoją pracę przy jak najmniejszym wysiłku, ale te drogi na skróty zwiększają czynniki ryzyka dla organizacji.
- **WAŻNE!!!**
- **Nie wszystkie usługi MFA są sobie równe.** Rozwiązania są bardzo zróżnicowane i często są wdrażane w sposób, który sprawia, że użytkownicy czują się nękani.

Dlaczego jest to tak ważne?

- Same dane logowania mogą nie wystarczyć do zapewnienia bezpieczeństwa konta
- Identity and Access Management (IAM) chroni:
 - Wrażliwe konta
 - Ważna infrastruktura internetowa
 - Wrażliwe dane firmowe



Cele MFA w uwierzytelnianiu

- Łatwe włączanie w dowolnym nowym lub istniejącym systemie
- Możliwość dostosowania przez administratora IAM na podstawie aktualnych potrzeb
- Bezpieczne i niezawodne
- Zaakceptowane przez wszystkich
- **Dostosowujemy MFA, a nie użytkowników.** Oparta na ryzyku, adaptacyjna usługa MFA poprawia wrażenia użytkownika, jednocześnie poprawiając bezpieczeństwo.

Do wyboru, do koloru

Usługa MFA może być dostępna przy użyciu:

- emaila
- YubiKey
- WebAuth
- SMSów
- kodów przywracania
- wiadomości (linków) wysyłanych na emaila
- haseł jednorazowych wysyłanych na emaila
- aplikacji uwierzytelniającej na urządzenia mobilne

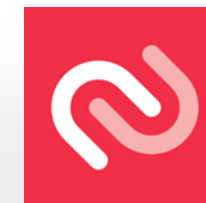
Do wyboru, do koloru

Bad: Password	Good: Password and...	Better: Password and...	Best: Passwordless
123456	 SMS	 Authenticator (Push Notifications)	 Authenticator (Phone Sign-in)
qwerty			 Window Hello
password	 Voice	 Software Tokens OTP	 FIDO2 security key
iloveyou			
Password1		 Hardware Tokens OTP (Preview)	 Certificates

Źródło: Microsoft

Sposób działania MFA

- Aplikacje umożliwiają zeskanowanie i zaimportowanie kodu QR zawierającego sekret MFA (plus dodatkowe szczegóły konta) za pomocą aparatu urządzenia (alternatywnie użytkownik może ręcznie wprowadzić te informacje)
- Przykłady aplikacji mobilnych obejmują Google Authenticator, Microsoft Authenticator, Authy itp.



Sposób działania MFA

- Sekret może być następnie używany przez aplikację do generowania haseł jednorazowych opartych na czasie co 30 sekund
- IAM również posiada ten sekret, więc zarówno aplikacja użytkownika, jak i IAM generują te same hasła w tym samym czasie
- W ten sposób można to wykorzystać do weryfikacji użytkownika

Kody przywracania

- Aby zapobiec zablokowaniu konta w przypadku utraty dostępu do urządzenia mobilnego, dla konta użytkownika generowane są awaryjne kody przywracania
- Są to hasła jednorazowe, używane w połączeniu z hasłem do konta głównego w celu przywrócenia dostępu
- Po ich użyciu można wygenerować nowe, kiedy tylko użytkownik sobie tego zażyczy
- Kody można przeglądać w dowolnym momencie w ustawieniach konta

Kody przywracania

Two-Step Authentication


Enter Phone
Number


Verify Code


Generate
Backup Codes

Backup codes let you access your account if your phone is lost, stolen, or if you run it through the washing machine and the bag of rice trick doesn't work.

We ask that you print this list of ten unique, one-time-use backup codes and keep the list in a safe place.

1. 04620462

2. 77707770

3. 23412341

4. 70327032

5. 85458545

6. 82690462

7. 10237770

8. 39472341

9. 84317032

10. 12868545

 Without access to the app, your phone, or a backup code, you will lose access to your account.

☐ I have printed or saved these codes

Print

All Finished!

Zabezpieczanie informacji /beatazalewa

- Użytkownicy mają kontrolę nad swoimi ustawieniami MFA

Zabezpieczanie informacji /beatazalewa

- Sekrety wieloskładnikowe i kody zapasowe są przechowywane w bezpiecznej bazie danych
- Wszystkie poufne informacje są haszowane i/lub szyfrowane w wysokim standardzie
- Użytkownicy mogą regenerować kody zapasowe w dowolnym czasie
- Konta zostaną zablokowane po kilku nieudanych próbach

Koncepcja Zero Trust

- Zero Trust to koncepcja bezpieczeństwa skupiająca się na przekonaniu, że organizacje nie powinny automatycznie ufać czemukolwiek i komukolwiek wewnątrz lub na zewnątrz sieci.
- Zamiast tego muszą weryfikować wszelkie próby połączenia się z systemami przed udzieleniem do nich dostępu.

Zasady koncepcji Zero Trust

Fundamentem systemu bezpieczeństwa opartego na modelu Zero Trust są trzy zasady:

- dokładna i jawna weryfikacja nie tylko tożsamości użytkowników, ale także urządzeń, danych i wszelkich anomalii,
- ograniczenie uprawnień użytkowników do niezbędnego zakresu i w określonym czasie,
- założenie próby włamania, a więc minimalizowanie skutków potencjalnego ataku poprzez segmentację sieci, użytkowników, urządzeń oraz aplikacji.

Zasady koncepcji Zero Trust

- Należy pamiętać, że nie istnieje ustalony schemat wdrażania podejścia Zero Trust w firmach i organizacjach.
- Tradycyjny model koncentrujący zabezpieczenia na brzegu sieci (budowanie tzw. „zamku i fosy”) się nie sprawdził – realną alternatywą jest właśnie model Zero Trust Security.

Obniżenie kosztów

- Czy warto oszczędzać na zespołach security, na zabezpieczeniach, na szkoleniu ludzi?
- Obniżenie kosztów może być kwestią dyskusyjną – nie warto oszczędzać na bezpieczeństwie
- Warto pamiętać, że często obniżenie ryzyka utraty danych jest tańsze niż koszty nieautoryzowanego dostępu



Bezpieczna praca zdalna

Jako pracodawca:

- Ustal zasady i procedury w firmie (przetestuj je wcześniej, jeśli to możliwe)
- Zabezpiecz komunikację w swojej firmie
- Zabezpiecz sprzęt firmowy
- Monitoruj stan bezpieczeństwa firmy
- Aktualizuj systemy operacyjne i aplikacje
- Uświadamiaj pracownikom zagrożenia związane z zdalną
- Zadbaj o bezpieczny dostęp zdalny



Bezpieczna praca zdalna

Jako pracownik:

- Używaj wyłącznie sprzętu pracodawcy w celu dostępu do firmowych danych
- Unikaj udostępniania danych osobowych
- Chronić sprzęt i środowisko pracy
- Zgłaszaj/ Informuj



Dobre praktyki

Zrozumienie wymagań

- Zdefiniowanie potrzeb, przypadków użycia i strategii wdrożenia

Przykładowe pytania:

- Czy rozwiązanie zapewnia szereg opcji dla wszystkich naszych zastosowań?
- Czy oferuje elastyczność w dodawaniu metod uwierzytelniania?
- Czy umożliwia obsługę wymagań dotyczących elastyczności, wyboru użytkownika i dostępu awaryjnego?

Dobre praktyki

Ocena rozwiązań

- Wybranie odpowiedniego rozwiązanie dla firm

Należy zadać sobie Pytanie:

- Co jest najważniejsze dla Twojej organizacji przy rozważaniu rozwiązania MFA?
 - a. Integracja z SSO
 - b. Poprawa doświadczenia użytkowników
 - c. Elastyczność kanałów dystrybucji

Dobre praktyki

Ocena użytkowników i aplikacji

- Wdrożenie na wszystkich użytkownikach i aplikacjach ogranicza narażenie na ryzyko wycieku i poprawia wrażenia użytkownika

Wybór czynników i taktyki dystrybucji

- Należy się zastanowić, co jest najlepsze dla naszych użytkowników

Podjęcie środków bezpieczeństwa mobilnego

- Walidacja urządzeń z bezpośrednim dostępem do systemów i danych

Dobre praktyki

Kluczowe atrybuty MFA:

- łatwe do wdrożenia
- łatwe w użyciu
- łatwe w zarządzaniu

Dziękuję za poświęcony czas



info@zalnet.pl



facebook.com/zalnet.beata.zalewa

github.com/beatazalewa

linkedin.com/in/beatazalewa



www.zalnet.pl